🚩 Sicherheits-Audit-Bericht: CyberFail Solutions Ltd.

1. Governance & Risk Management

- **Informationssicherheitspolitik:** Es existiert kein schriftliches Regelwerk. Sicherheitsentscheidungen werden ad-hoc durch die IT-Praktikanten getroffen; eine Freigabe durch das Management erfolgt nicht.
- **Sicherheitsbeauftragter:** Es gibt keine dedizierte Rolle für Cybersicherheit. Die Verantwortung ist diffus auf alle Mitarbeiter verteilt, ohne klare Rechenschaftspflicht.
- **Risikoanalysen:** Eine systematische Bewertung von Cyber-Risiken findet nicht statt. Strategische Änderungen an der Infrastruktur werden ohne vorherige Sicherheitsprüfung implementiert.

2. Access & Identity

- **Multi-Faktor-Authentifizierung (MFA):** Administratoren loggen sich ausschließlich mit Benutzername und Passwort ein. Remote-Zugänge (VPN) verfügen über keinen zweiten Faktor.
- **Berechtigungskonzept:** Alle Mitarbeiter besitzen „Domain Admin“-Rechte in der Produktionsumgebung, um „Workflows nicht durch Bürokratie zu behindern“.
- **Revisionsprozesse:** Zugriffsrechte werden nach dem Ausscheiden von Mitarbeitern nicht entzogen. Eine regelmäßige Überprüfung der Berechtigungen findet nicht statt.

3. Data Protection & Privacy

- **Datenklassifizierung:** Sensible Kundendaten werden zusammen mit Marketingmaterialien in ungeschützten Ordnern gespeichert. Es gibt keine Richtlinien zur Handhabung von PII (Personenbezogenen Daten).
- **DPAs & Sub-Auftragsverarbeiter:** Verträge mit Drittanbietern enthalten keine Datenschutzklauseln. Eine Liste der genutzten Sub-Dienstleister existiert nicht.
- **Verschlüsselung:** Daten werden im Ruhezustand (at rest) im Klartext gespeichert. Die Übertragung erfolgt über unverschlüsseltes HTTP und FTP.

4. Cryptography & Key Management

- **Schlüsselmanagement:** Kryptografische Schlüssel sind hartcodiert im Quellcode hinterlegt. Ein Rotationsprozess oder ein sicheres Speicherkonzept existiert nicht.

- **HSM / Customer-Managed Keys:** Die Nutzung von Hardware-Sicherheitsmodulen wird nicht unterstützt. Kunden haben keine Möglichkeit, eigene Schlüssel einzubringen.

5. Operations & Monitoring

- **Logging:** Protokolldateien werden lokal auf den jeweiligen Servern gespeichert und nach 24 Stunden automatisch gelöscht, um Speicherplatz zu sparen.
- **24/7 Monitoring:** Es gibt keine Überwachung außerhalb der Kernarbeitszeiten (Mo-Fr, 09:00-16:00 Uhr). Eskalationspfade für Notfälle sind nicht definiert.
- **Vulnerability Management:** Sicherheitslücken werden nur sporadisch und ohne definierten Zeitplan (SLAs) geschlossen. Ein Patch-Management-Prozess fehlt völlig.

6. Incident & Business Continuity

- **Incident Response (IRP):** Es gibt keinen Plan für den Umgang mit Sicherheitsvorfällen. Kunden werden im Falle eines Datenlecks nicht aktiv informiert.
- **Tabletop-Tests:** Sicherheitsübungen oder Simulationen von Angriffen (z. B. Ransomware) wurden noch nie durchgeführt.
- **BCDR-Pläne:** Es existieren keine Disaster-Recovery-Pläne. Wiederherstellungsziele (RTO/RPO) sind nicht definiert; Backups werden nicht auf Integrität geprüft.

7. Supply Chain & Development

- **Secure SDLC:** Die Softwareentwicklung folgt keinem Sicherheitsstandard. Code-Reviews, Bedrohungsanalysen (Threat Modeling) oder automatisierte Scans finden nicht statt.
- **Drittanbieter-Komponenten:** Open-Source-Bibliotheken werden ohne Prüfung auf bekannte Schwachstellen eingebunden. Es gibt keine Software Bill of Materials (SBOM).
- **Penetrationstests:** Es wurden seit Firmengründung keine unabhängigen Sicherheitsüberprüfungen oder Penetrationstests durchgeführt.